

IT-SIMPLERA INSTITUTE

Cyber Security Analyst Internship Program

WEEK 06 ASSIGNMENT

Cybersecurity Fundamentals & Security Concepts

Active Directory Design, Administration & Enumeration Report

Submitted By: Noman zafar

Prepared for: TechSecure Solutions (Fictional Organization)

Prepared By: Talal | Reviewed By: Rehan

Assigned To: Cyber Security Analyst Interns

Submission Deadline: 8 August 2026

Table of Contents

1. Introduction
2. Task 1 - Enterprise Active Directory Design
3. Task 2 - Users, Groups & Permission Planning
4. Task 3 - Group Policy & Security Configuration
5. Task 4 - Active Directory Practical (Windows Server) - Lab Steps
6. Task 5 - Basic Kali Linux Enumeration - Lab Steps
7. Task 6 - Case Study & Troubleshooting
8. Challenges
9. Conclusion
10. References

1. Introduction

This report documents Week 6 of the Cyber Security Analyst Internship at IT-Simplera Institute. Acting as a Junior System Administrator and Security Analyst for the fictional organization TechSecure Solutions (300 employees, 5 departments, 2 branch offices), this report designs an enterprise Active Directory environment, plans users, groups and shared-folder permissions, defines Group Policy security controls, and lays out the exact lab steps required to perform the Windows Server AD practical and the Kali Linux defensive enumeration exercise. It closes with a troubleshooting case study and an incident report for a real-world authentication scenario.

2. Task 1 - Enterprise Active Directory Design

2.1 Design Summary

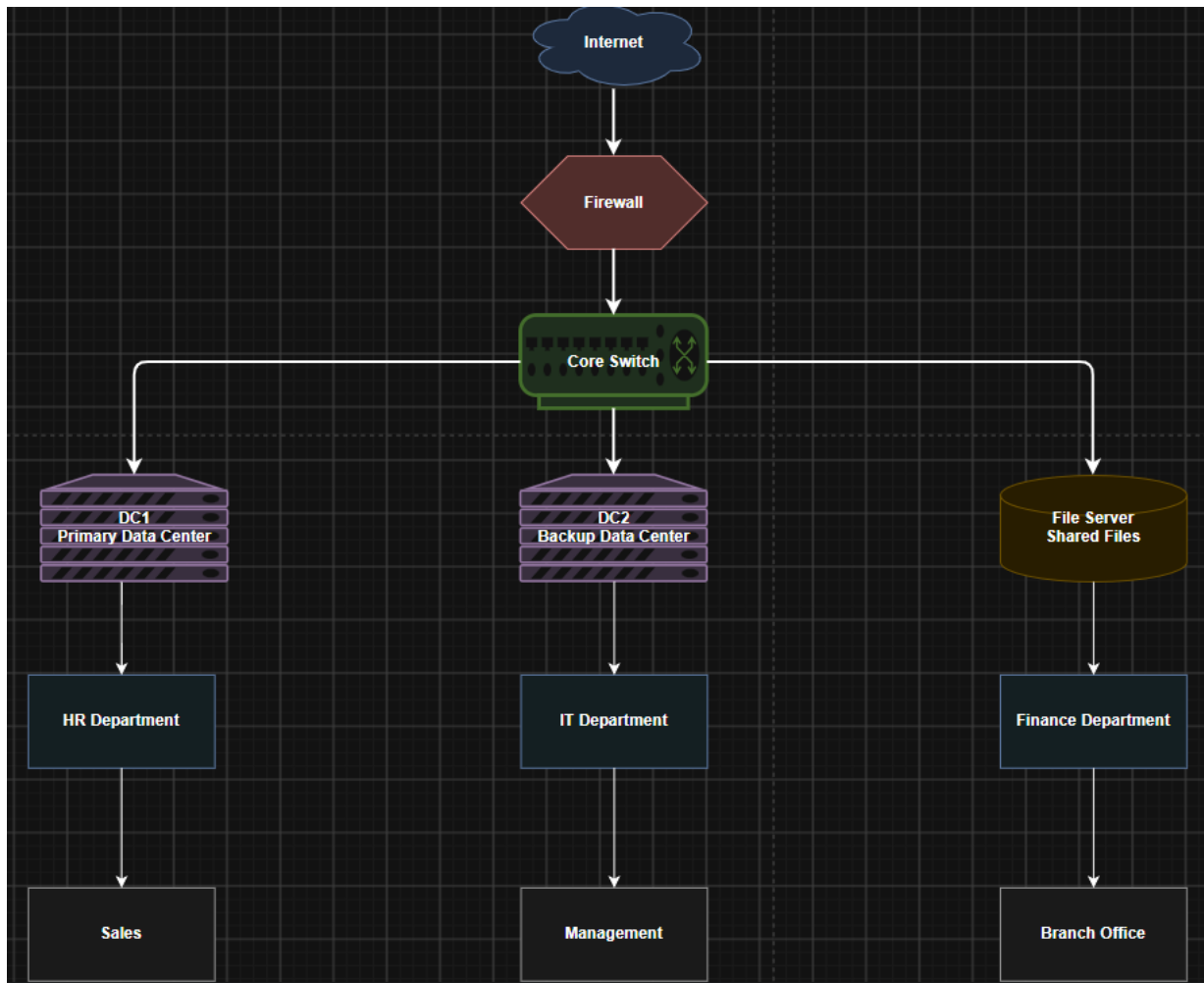
- Forest: 1 forest — techsecure.local
- Domain: 1 domain — techsecure.local
- Domain Controllers: 2 — DC01 (Branch 1/HQ, holds all FSMO roles, primary Global Catalog) and DC02 (Branch 2, additional DC / Global Catalog, provides redundancy and local authentication for the branch)
- Organizational Units (8 total): OU-HR, OU-IT, OU-Finance, OU-Sales, OU-Management, OU-Servers, OU-Workstations, OU-ServiceAccounts

Deliverable files (draw.io): 1_Network_Diagram.drawio, 2_OU_Diagram.drawio, 3_Authentication_Flow_Diagram.drawio — see Section 2.2 for import instructions.

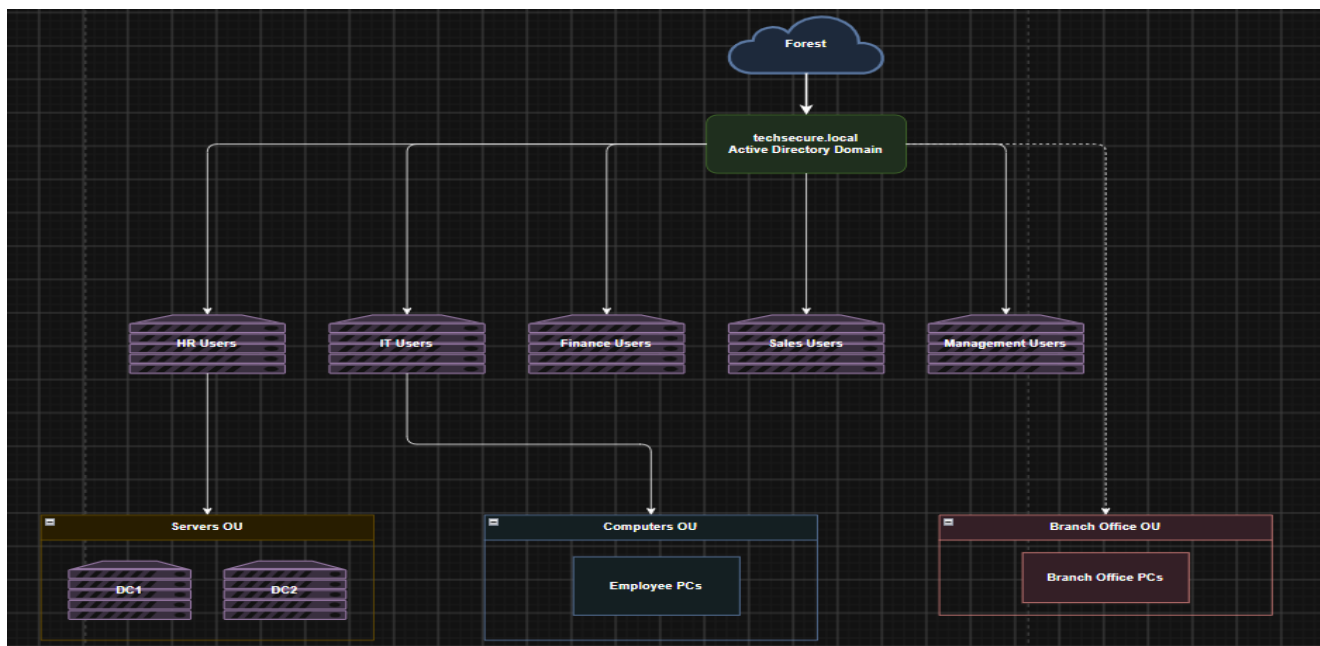
2.2 Explanation (OU Placement & Security Rationale)

Each of the five departments (HR, IT, Finance, Sales, Management) has its own OU so that department-specific Group Policies, delegated administration, and password/security baselines can be applied without affecting other teams, while three additional OUs — Servers, Workstations, and ServiceAccounts — separate computer objects and non-human accounts from user accounts because machines and service accounts need entirely different GPOs (e.g., firewall and update policies) and a much tighter security posture (no interactive logon, no password expiry prompts) than regular staff; this separation also lets IT delegate department-level user management (such as password resets) to team leads without granting them any rights over servers or service accounts, it makes it possible to link tightly scoped GPOs (like blocking USB storage or restricting CMD/PowerShell) precisely to the OUs that need them, it shrinks the blast radius of a compromised account because an attacker who takes over a Sales OU account cannot directly reach Management or Server OUs, and it keeps auditing and troubleshooting straightforward since every object's location in the OU tree immediately shows which policies and permissions apply to it — together these choices reduce the attack surface, enforce least privilege, and make the whole domain easier to secure and administer as TechSecure Solutions grows across its two branch offices.

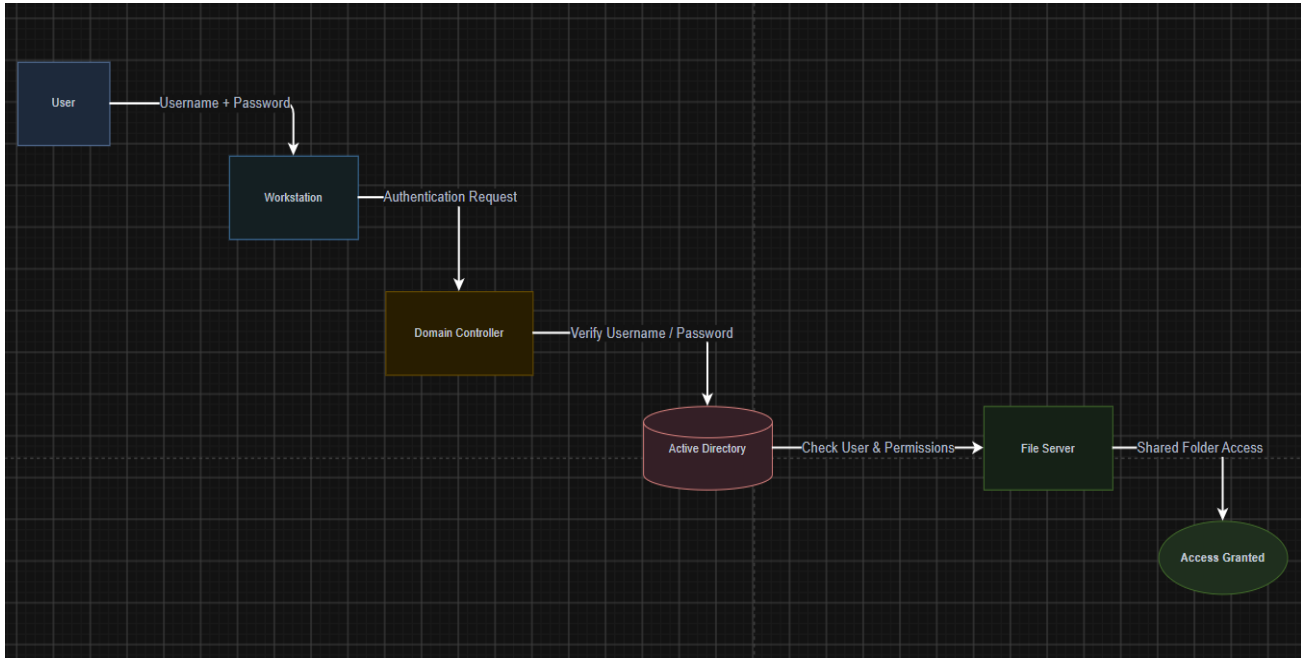
2.3 Network Diagram:



2.4 OU Diagram:



2.5 Authentication



3. Task 2 - Users, Groups & Permission Planning (20 Marks)

3.1 Users (25)

Full Name	Username	Department	Job Title	Group Membership	Access Rights
Ayesha Khan	akhan	HR	HR Generalist	SG-HR-Staff, SG-AllEmployees	Read: HR-Shared
Bilal Ahmed	bahmed	HR	HR Manager	SG-HR-Managers, SG-AllEmployees	Modify: HR-Shared
Sara Malik	smalik	HR	Recruiter	SG-HR-Staff, SG-AllEmployees	Read: HR-Shared
Usman Tariq	utariq	HR	Payroll Officer	SG-HR-Staff, SG-AllEmployees	Read: HR-Shared, Finance-Shared
Hina Rauf	hrauf	HR	HR Assistant	SG-HR-Staff, SG-AllEmployees	Read: HR-Shared
Talal Rehan	trehan	IT	IT Administrator	SG-IT-Admins, SG-AllEmployees	Full Control: IT-Shared; Read: all shares
Zainab Iqbal	ziqbal	IT	Network Engineer	SG-IT-Admins, SG-AllEmployees	Full Control: IT-Shared
Faizan Sheikh	fsheikh	IT	Help Desk Technician	SG-IT-Admins, SG-AllEmployees	Modify: IT-Shared
Mariam Yousuf	myousuf	IT	Systems Administrator	SG-IT-Admins, SG-AllEmployees	Full Control: IT-Shared
Kamran Ali	kali	IT	Security Analyst	SG-IT-Admins, SG-AllEmployees	Full Control: IT-Shared; Read: all shares (audit)
Nida Farooq	nfarooq	Finance	Finance Manager	SG-Finance-Managers, SG-AllEmployees	Modify: Finance-Shared

Full Name	Username	Department	Job Title	Group Membership	Access Rights
Omar Siddiqui	osiddiqui	Finance	Accountant	SG-Finance-Staff, SG-AllEmployees	Read: Finance-Shared
Rabia Chaudhry	rchaudhry	Finance	Accounts Payable Officer	SG-Finance-Staff, SG-AllEmployees	Read: Finance-Shared
Adeel Nasir	anasir	Finance	Financial Analyst	SG-Finance-Staff, SG-AllEmployees	Read: Finance-Shared
Sana Riaz	sriaz	Finance	Internal Auditor	SG-Finance-Staff, SG-AllEmployees	Read: Finance-Shared
Hamza Qureshi	hqureshi	Sales	Sales Manager	SG-Sales-Managers, SG-AllEmployees	Modify: Sales-Shared
Iqra Basit	ibasit	Sales	Sales Executive	SG-Sales-Staff, SG-AllEmployees	Read: Sales-Shared
Danish Anwar	danwar	Sales	Sales Executive	SG-Sales-Staff, SG-AllEmployees	Read: Sales-Shared
Mahnour Saeed	msaeed	Sales	Business Development Officer	SG-Sales-Staff, SG-AllEmployees	Read: Sales-Shared
Waqas Aslam	waslam	Sales	Sales Coordinator	SG-Sales-Staff, SG-AllEmployees	Read: Sales-Shared
Farhan Malik	fmalik	Management	CEO	SG-Management-ExecTeam, SG-AllEmployees	Full Control: Management-Shared
Ayesha Noor	anoor	Management	COO	SG-Management-ExecTeam, SG-AllEmployees	Full Control: Management-Shared
Bilal Haider	bhaider	Management	CFO	SG-Management-ExecTeam, SG-Finance-Managers, SG-AllEmployees	Full Control: Management-Shared; Modify: Finance-Shared
Sadia Kazmi	skazmi	Management	HR Director	SG-Management-ExecTeam, SG-HR-Managers, SG-AllEmployees	Full Control: Management-Shared; Modify: HR-Shared
svc-backup	svc-backup	IT (Service Account)	Backup Service Account	SG-ServiceAccounts	Modify (backup jobs only) on all shares; no interactive logon

3.2 Security Groups (10)

Group Name	Type/Scope	Members / Purpose	Assigned Access
SG-HR-Staff	Global Security	General HR department staff	Read on HR-Shared
SG-HR-Managers	Global Security	HR management / team leads	Modify on HR-Shared
SG-IT-Admins	Global Security	IT department & system administrators	Full Control on IT-Shared; delegated admin rights
SG-Finance-Staff	Global Security	General Finance department staff	Read on Finance-Shared
SG-Finance-Managers	Global Security	Finance management / team leads	Modify on Finance-Shared
SG-Sales-Staff	Global Security	General Sales department staff	Read on Sales-Shared
SG-Sales-Managers	Global Security	Sales management / team leads	Modify on Sales-Shared

Group Name	Type/Scope	Members / Purpose	Assigned Access
SG-Management-ExecTeam	Global Security	CEO, COO, CFO, HR Director (executives)	Full Control on Management-Shared
SG-AllEmployees	Global Security	All 300 employees (baseline access)	Read on IT-Shared\Public (company announcements/policies)
SG-ServiceAccounts	Global Security	Non-interactive service & backup accounts	Restricted; Modify only for scheduled backup jobs

3.3 Shared Folders & Permissions (5)

Folder	Read	Modify	Full Control	Denied
HR-Shared	SG-HR-Staff, SG-Management-ExecTeam (view only)	SG-HR-Managers	SG-IT-Admins (custodial)	SG-Sales-Staff, SG-Finance-Staff, SG-ServiceAccounts
Finance-Shared	SG-Finance-Staff	SG-Finance-Managers	SG-IT-Admins (custodial)	SG-Sales-Staff, SG-HR-Staff, SG-ServiceAccounts
Sales-Shared	SG-Sales-Staff, SG-Management-ExecTeam	SG-Sales-Managers	SG-IT-Admins (custodial)	SG-ServiceAccounts
IT-Shared	SG-AllEmployees (Public sub-folder only)	SG-IT-Admins	SG-IT-Admins	None (segmented by sub-folder ACLs)
Management-Shared (Confidential)	SG-Management-ExecTeam	SG-Management-ExecTeam	SG-IT-Admins (custodial)	SG-HR-Staff, SG-Finance-Staff, SG-Sales-Staff, SG-ServiceAccounts

3.4 Analysis Questions

Which account would attackers target first, and why?

The IT Administrator / systems-administrator accounts (e.g., trehan, myousuf) and the svc-backup service account would be the first targets: the human IT-admin accounts hold Full Control across every departmental share and can reset any user's password, so compromising one gives an attacker domain-wide reach in a single step, while svc-backup is even more attractive because service accounts typically use non-expiring passwords, are excluded from interactive-logon monitoring, and are rarely covered by MFA — making them a quiet, high-privilege foothold that is less likely to trigger alerts.

Which permissions violate the Least Privilege Principle?

Two violations stand out: SG-IT-Admins holding blanket Full Control over every departmental share (including HR-Shared and Management-Shared) rather than only IT-Shared, purely to perform routine maintenance; and svc-backup being granted Modify rights on every shared folder instead of a purpose-built backup right, which gives a single non-interactive account far more access than its backup job actually requires.

How would you fix those permissions?

Replace the IT-Admins' blanket Full Control with a scoped "custodial" right (List Folder Contents / Take Ownership only, invoked on demand) on sensitive shares, keeping Full Control only on IT-Shared where they are the true data owners; and replace svc-backup's Modify permission with the built-in Backup Operators privilege

(SeBackupPrivilege/SeRestorePrivilege) so it can read all files for backup purposes without holding standing write/modify access to any share.

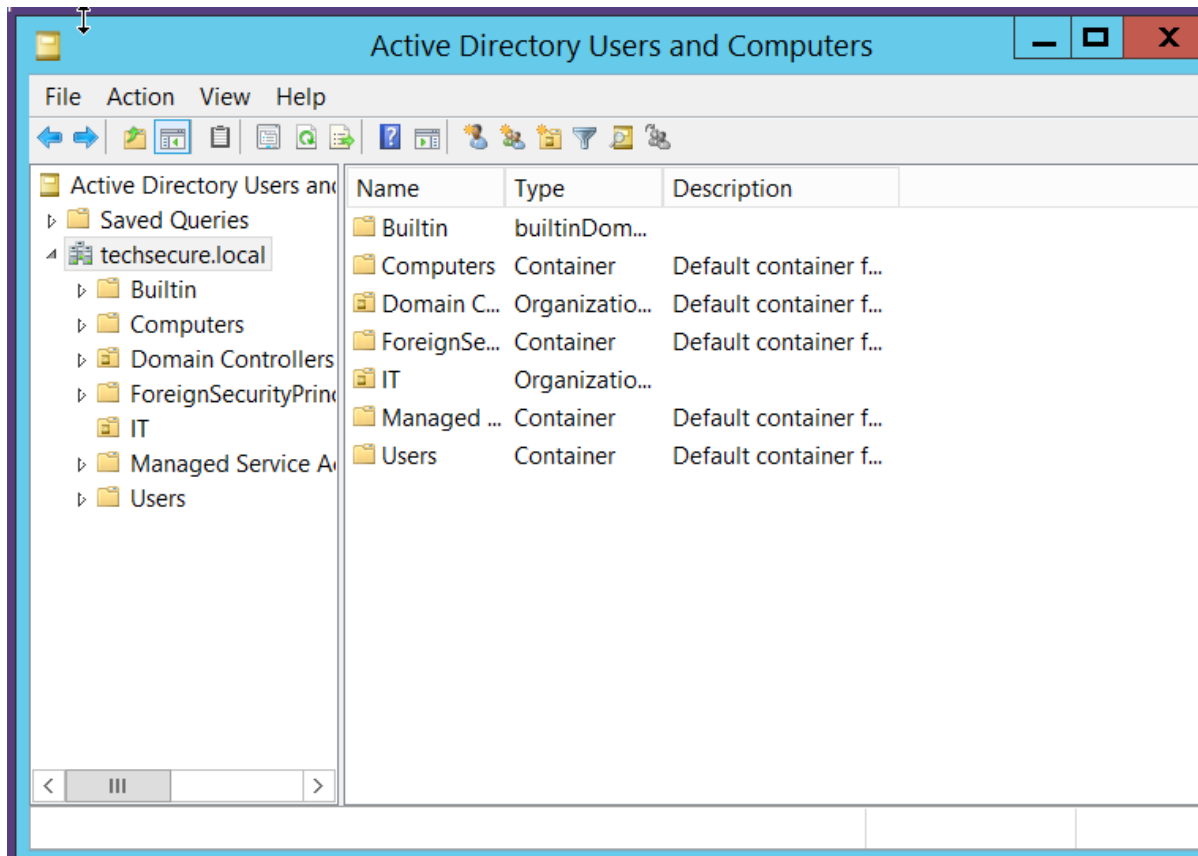
4. Task 3 - Group Policy & Security Configuration

Group Policy	Why It Is Required	Who It Affects	Cyberattack It Helps Prevent
Password Complexity Policy	Enforces min. 12-character passwords with mixed case, numbers and symbols	All domain users	Brute-force and dictionary password attacks
Account Lockout Policy	Locks an account for 15 minutes after 5 failed logon attempts	All domain users	Brute-force and credential-stuffing attacks
Disable USB Storage	Blocks removable USB storage devices via Removable Storage Access policy	All standard users (excludes SG-IT-Admins)	Data exfiltration and USB-borne malware (BadUSB)
Restrict CMD & PowerShell	Disables cmd.exe and restricts PowerShell execution policy for non-IT staff	All users except SG-IT-Admins	Living-off-the-land attacks and malicious script execution
Enable Windows Firewall (Domain Profile)	Ensures the firewall is on with defined inbound/outbound rules	All computers (workstations & servers)	Network scanning and lateral movement
Automatic Updates / WSUS	Forces timely download and installation of security patches	All computers	Exploitation of known, unpatched CVEs
Screen Lock / Session Timeout	Locks the workstation after 5 minutes of inactivity	All users	Unauthorized physical access to an unattended session
BitLocker Drive Encryption	Enforces full-disk encryption on laptops and desktops	All laptop users, especially Sales and Management (mobile staff)	Data theft from a lost or stolen device
Windows Defender Enforcement	Keeps real-time protection on and prevents users from disabling it	All computers	Malware and ransomware execution
Advanced Audit Policy	Logs logon events, object access and account/group changes	All Domain Controllers and file servers	Undetected intrusions and insider threats; enables incident response

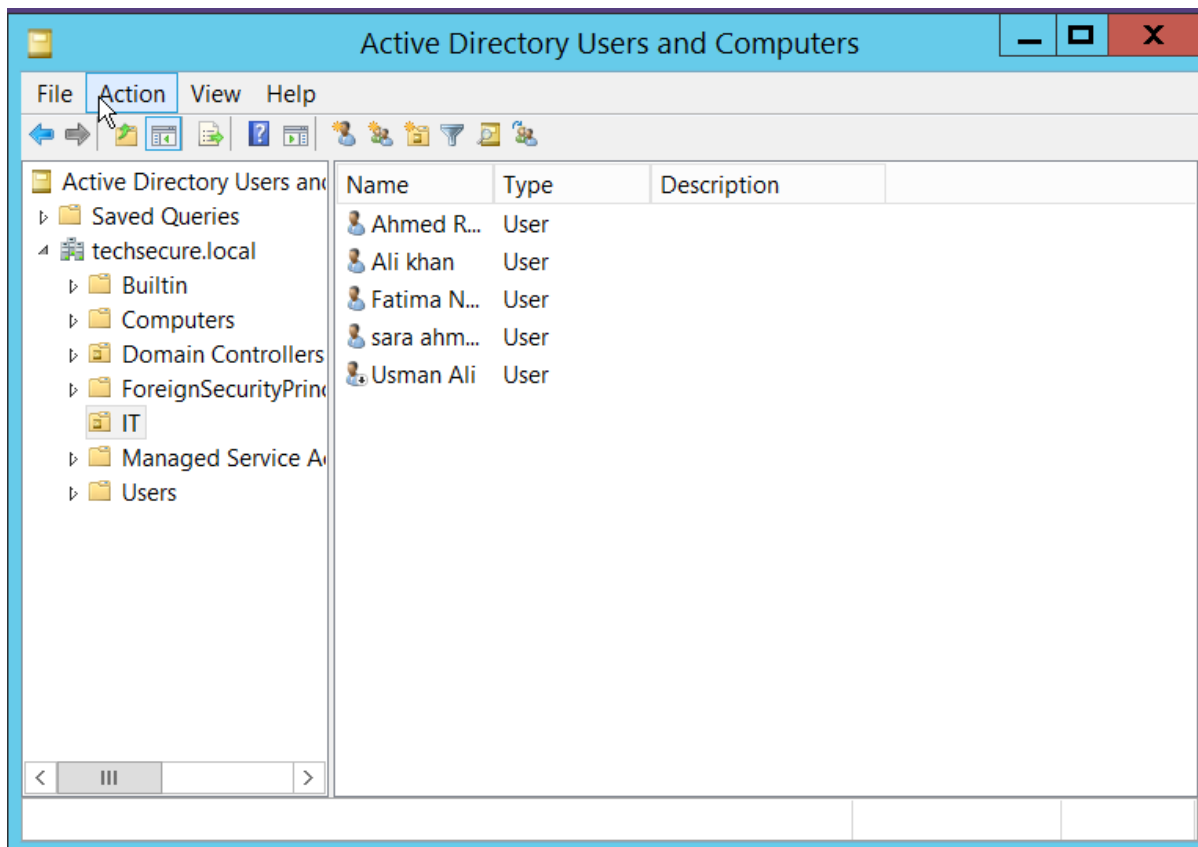
5. Task 4 - Active Directory Practical (Windows Server) - Lab Steps

This task must be completed hands-on inside a Windows Server AD lab (e.g., Windows Server 2019/2022 + a Windows 10/11 client in VirtualBox/VMware/Hyper-V). Follow the numbered steps below in your own lab, and paste the requested screenshot in the marked box directly under each step before exporting the final report.

Create One Organizational Unit

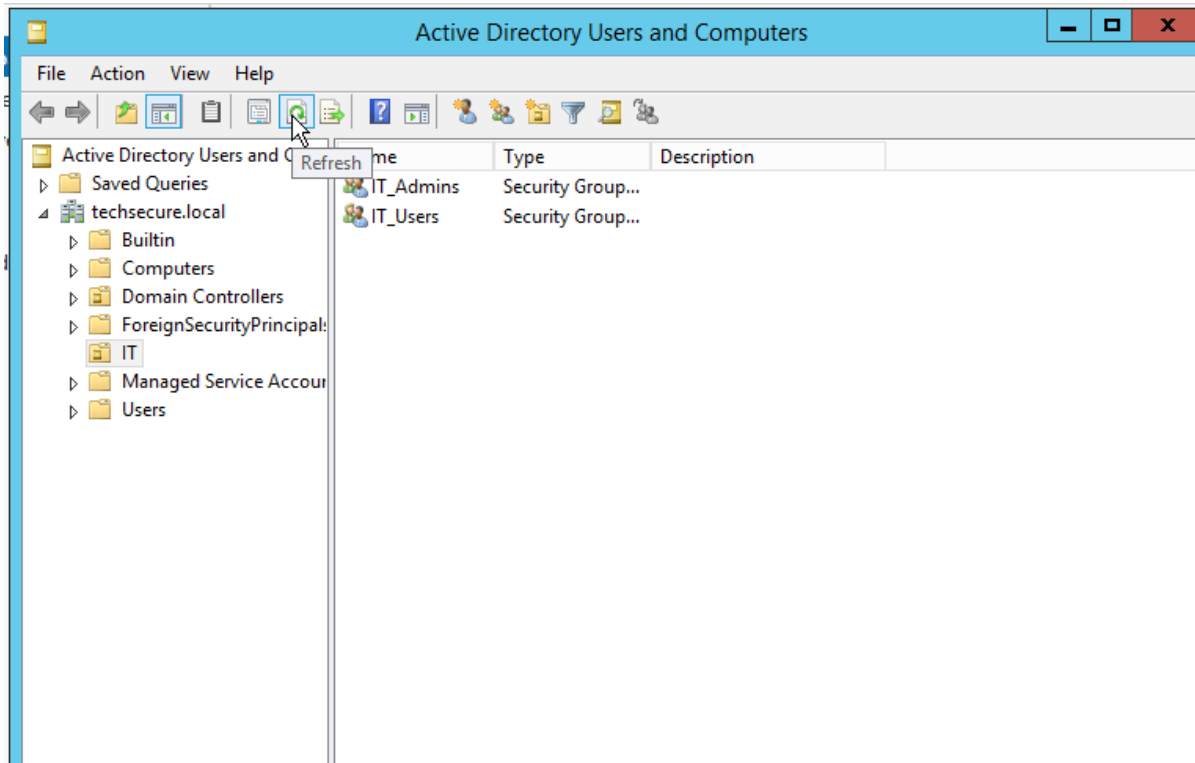


Create Five Users



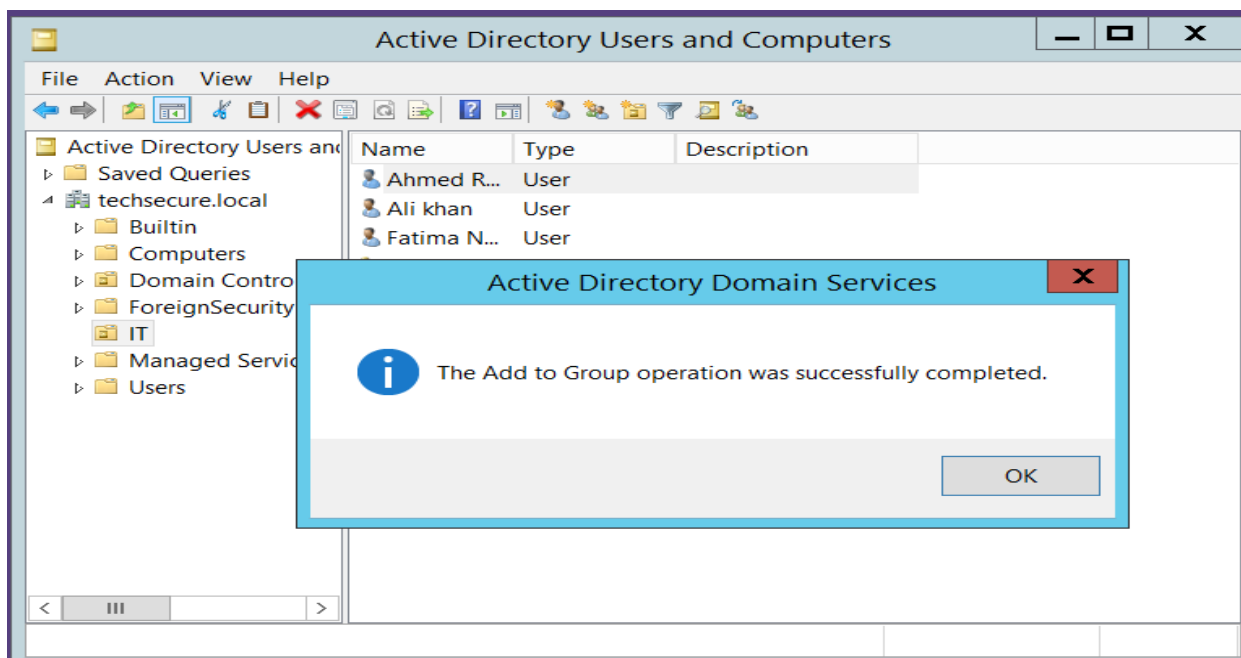
Create Two Security Groups

Right-click OU-Pilot-Test > New > Group. Set Group scope = Global and Group type = Security. Create two groups, e.g. SG-Pilot-Read and SG-Pilot-Modify.



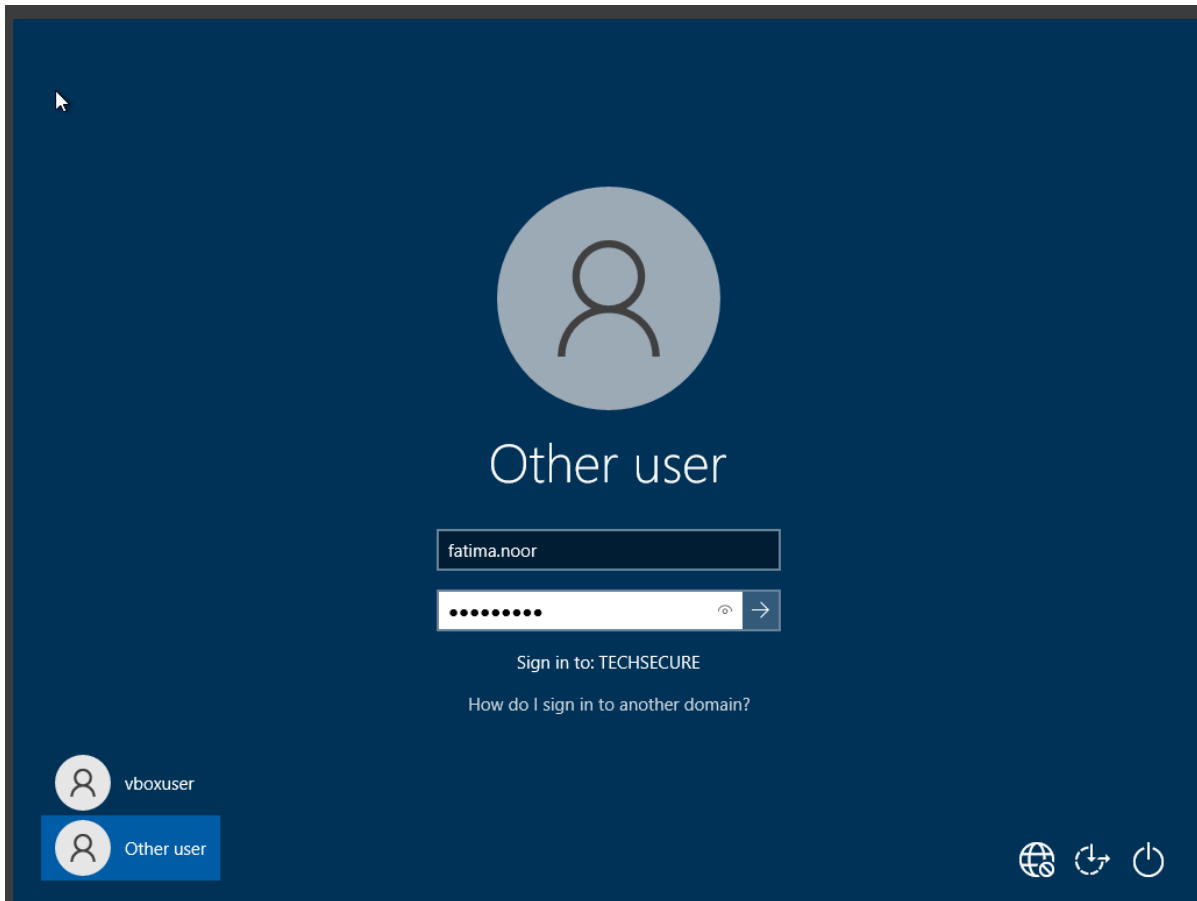
Add Users to Groups

Open a group's Properties > Members tab > Add, then type the usernames to add (or drag-and-drop users onto the group). Confirm the Members tab lists them.



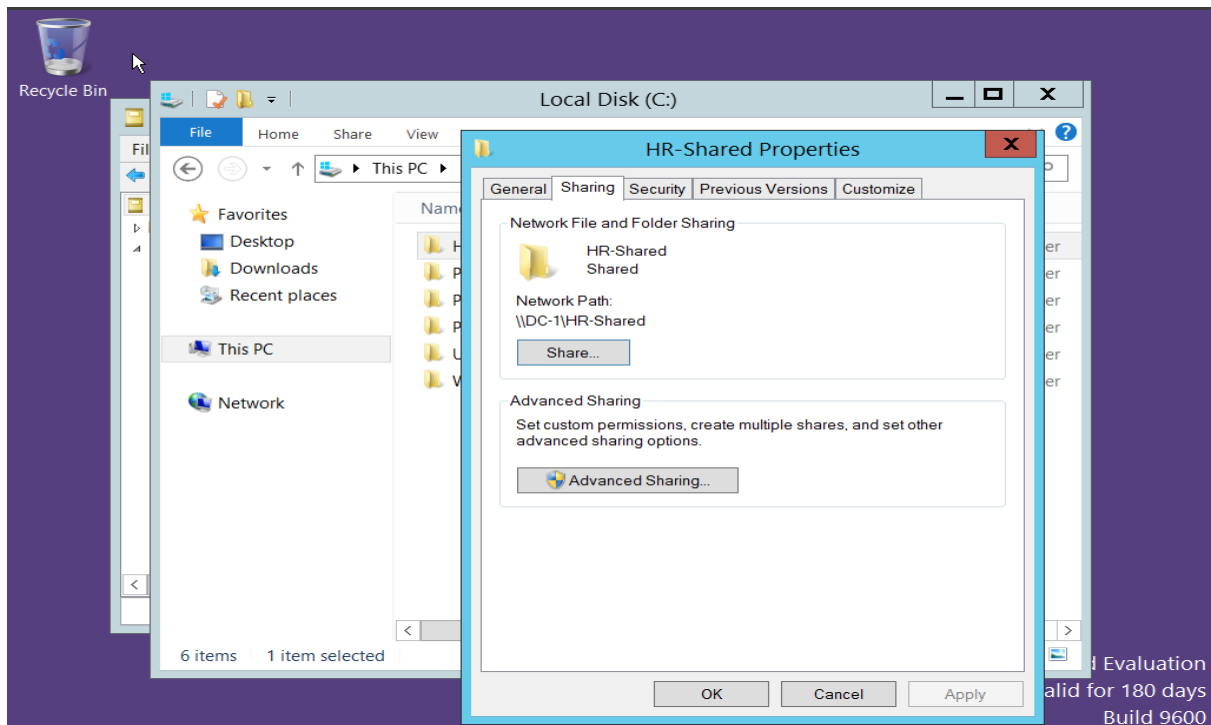
Step 6 - Join a Windows Client to the Domain

On the Windows client VM: This PC > Properties > Rename this PC (Advanced) > Change > select Domain, enter techsecure.local, provide domain admin credentials when prompted, then restart the VM.

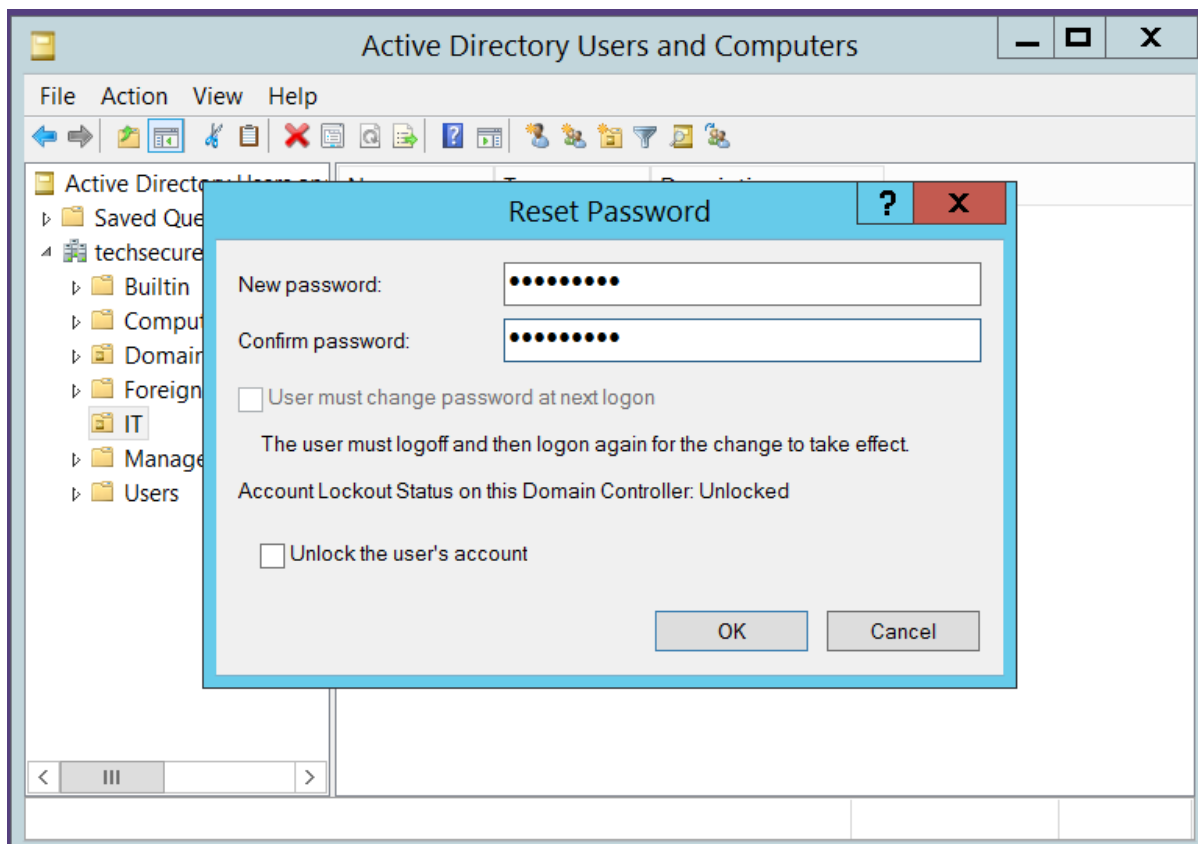


Create One Shared Folder

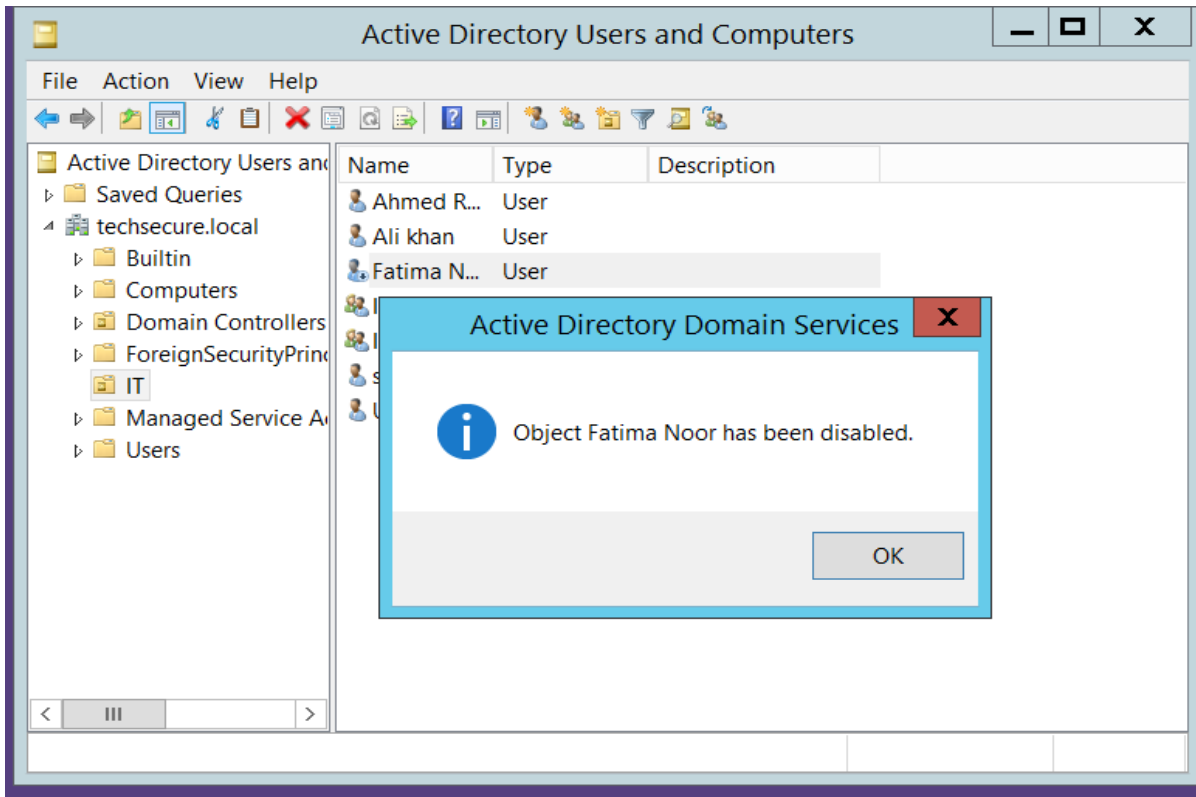
On the server, create a folder (e.g., C:\Shares\PilotShare). Right-click > Properties > Sharing tab > Advanced Sharing > check 'Share this folder' > OK.



Step 9 - Reset One User's Password



Step 10 - Disable One User Account



Step 11 -

6. Task 5 - Basic Kali Linux Enumeration - Lab Steps

Perform this task only inside your own isolated lab network against your own Windows Server VM. Never scan a host you do not own or have explicit permission to test.

Command 1 - Identify the Live Host

Command: ping 10.0.2.4

```
(kali㉿kali)-[~]
$ ping 10.0.2.15
PING 10.0.2.15 (10.0.2.15) 56(84) bytes of data:
64 bytes from 10.0.2.15: icmp_seq=1 ttl=128 time=0.560 ms
64 bytes from 10.0.2.15: icmp_seq=2 ttl=128 time=0.630 ms
64 bytes from 10.0.2.15: icmp_seq=3 ttl=128 time=0.419 ms
^C
--- 10.0.2.15 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2093ms
rtt min/avg/max/mdev = 0.419/0.536/0.630/0.087 ms
```

What it reveals: Confirms the target IP is online and reachable. Why it matters to defenders: Live-host discovery is normally the very first step of any attacker's reconnaissance, so seeing this traffic in logs is an early warning sign.

Command 2 - Discover Open Ports

Command: `nmap -sS -Pn <DC-IP>`

```
(kali㉿kali)-[~]
$ nmap -sS -Pn 10.0.2.15
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-08 02:11 EDT
Nmap scan report for 10.0.2.15
Host is up (0.00034s latency).
Not shown: 983 filtered tcp ports (no-response)
PORT      STATE SERVICE
53/tcp    open  domain
88/tcp    open  kerberos-sec
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
389/tcp   open  ldap
445/tcp   open  microsoft-ds
464/tcp   open  kpasswd5
593/tcp   open  http-rpc-epmap
636/tcp   open  ldapssl
3268/tcp  open  globalcatLDAP
3269/tcp  open  globalcatLDAPssl
5985/tcp  open  wsman
49154/tcp open  unknown
49155/tcp open  unknown
49157/tcp open  unknown
49158/tcp open  unknown
49159/tcp open  unknown
MAC Address: 08:00:27:64:3D:B0 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
```

What it reveals: Which TCP services are listening (e.g., 53 DNS, 88 Kerberos, 389 LDAP, 445 SMB). Why it matters to defenders: Open ports map directly to the attack surface; unnecessary open ports should be closed or firewalled.

Command 3 - Identify the Domain Controller

Command: `nmap -p 88,389,445,3268 -sV <DC-IP>`

```
(kali㉿kali)-[~]
$ nmap -p 88,389,445,3268 -sV 10.0.2.15
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-08 02:12 EDT
Nmap scan report for 10.0.2.15
Host is up (0.00046s latency).
PORT      STATE SERVICE      VERSION
88/tcp    open  kerberos-sec Microsoft Windows Kerberos (server time: 2026-08-08 18:14:55Z)
389/tcp   open  ldap         Microsoft Windows Active Directory LDAP (Domain: techsecure.local, Site: Default-First-S
445/tcp   open  microsoft-ds Microsoft Windows Server 2008 R2 - 2012 microsoft-ds (workgroup: TECHSECURE)
3268/tcp  open  ldap         Microsoft Windows Active Directory LDAP (Domain: techsecure.local, Site: Default-First-S
MAC Address: 08:00:27:64:3D:B0 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Host: DC-1; OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.36 seconds
```

What it reveals: The presence of Kerberos (88), LDAP (389), SMB (445) and Global Catalog (3268) together strongly indicates the host is a Domain Controller. Why it matters to defenders: Knowing which hosts are DCs highlights the highest-value assets that need the strictest monitoring and hardening.

Command 4 - Discover the Domain Name

Command: nslookup <DC-IP> (and) nslookup techsecure.local

```
(kali㉿kali)-[~]
$ nslookup 10.0.2.15
** server can't find 15.2.0.10.in-addr.arpa: NXDOMAIN

(kali㉿kali)-[~]
$ nslookup techsecure.local
;; communications error to 192.168.1.1#53: timed out
Server:          192.168.1.1
Address:         192.168.1.1#53

** server can't find techsecure.local: NXDOMAIN
```

What it reveals: The FQDN of the domain and DNS server in use. Why it matters to defenders: DNS is foundational to AD; exposed or misconfigured DNS can leak internal naming conventions attackers use for phishing or further enumeration.

Command 5 - Confirm the Domain Controller via DNS SRV Records

Command: dig SRV _ldap._tcp.dc._msdcs.techsecure.local @<DC-IP>

```
(kali㉿kali)-[~]
$ dig SRV _ldap._tcp.dc._msdcs.techsecure.local @10.0.2.15

; <<>> DiG 9.20.11-4+b1-Debian <<>> SRV _ldap._tcp.dc._msdcs.techsecure.local @10.0.2.15
;; global options: +cmd
;; Got answer:
;; WARNING: .local is reserved for Multicast DNS
;; You are currently testing what happens when an mDNS query is leaked to DNS
;; ->>HEADER<<- opcode: QUERY, status: FORMERR, id: 9018
;; flags: qr rd; QUERY: 1, ANSWER: 0, AUTHORITY: 0, ADDITIONAL: 1
;; WARNING: recursion requested but not available

;; OPT PSEUDOSECTION:
;; EDNS: version: 0, flags:; udp: 1232
;; COOKIE: b59003d582d24dd8 (echoed)
;; QUESTION SECTION:
;; _ldap._tcp.dc._msdcs.techsecure.local. IN SRV

;; Query time: 0 msec
;; SERVER: 10.0.2.15#53(10.0.2.15) (UDP)
;; WHEN: Sat Aug 08 02:15:39 EDT 2026
;; MSG SIZE rcvd: 78
```

What it reveals: The exact hostname of the Domain Controller registered for LDAP. Why it matters to defenders: SRV records should only be resolvable from trusted internal networks; external exposure of these records is a red flag.

Command 6 - Enumerate SMB Shares and AD Details

Command: enum4linux-ng -A <DC-IP>

```
(kali㉿kali)-[~]
└─$ enum4linux-ng -A 10.0.2.15
ENUM4LINUX - next generation (v1.3.10)

=====
|      Target Information      |
=====
[*] Target ..... 10.0.2.15
[*] Username ..... ''
[*] Random Username .. 'xajewepe'
[*] Password ..... ''
[*] Timeout ..... 10 second(s)

=====
|      Listener Scan on 10.0.2.15      |
=====
[*] Checking LDAP
[+] LDAP is accessible on 389/tcp
[*] Checking LDAPS
[+] LDAPS is accessible on 636/tcp
[*] Checking SMB
[+] SMB is accessible on 445/tcp
[*] Checking SMB over NetBIOS
[+] SMB over NetBIOS is accessible on 139/tcp

=====
|      Domain Information via LDAP for 10.0.2.15      |
=====
[*] Trying LDAP
[+] Appears to be root/parent DC
```

What it

reveals: SMB shares, share permissions, OS version, and sometimes user/group names via null or guest sessions. Why it matters to defenders: This is exactly what an unauthenticated attacker could learn; the fix is disabling null sessions/anonymous enumeration (RestrictAnonymous) and locking down guest access.

Command 7 - List SMB Shares Directly

Command: smbclient -L //<DC-IP>/ -N

```
(kali㉿kali)-[~]
└─$ smbclient -L //10.0.2.15/ -N
Anonymous login successful

      Sharename      Type      Comment
      -----
Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to 10.0.2.15 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
Unable to connect with SMB1 -- no workgroup available
```


What it reveals: The names of shared folders exposed over SMB (e.g., NETLOGON, SYSVOL, and any custom shares). Why it matters to defenders: Confirms whether sensitive shares are unintentionally reachable without authentication.

7. Task 6 - Case Study & Troubleshooting

Scenario: A user reports they cannot log in to the domain, their password was changed yesterday, and they also cannot access the shared HR folder.

7.1 Ten Possible Causes

- 1. The new password has not yet replicated from DC01 to DC02 (AD replication delay).
- 2. The user is mistyping the new password (Caps Lock on, wrong keyboard layout, or autofill using the old password).
- 3. The account is locked out from earlier failed attempts made by a cached-credential device (phone, old laptop) still using the old password.
- 4. The account was accidentally disabled by an administrator during the password reset.
- 5. The password was set with 'User must change password at next logon' and the user has not completed that step correctly.
- 6. Client-server time skew exceeding the 5-minute Kerberos tolerance is causing authentication (KRB_AP_ERR_SKEW) to fail.
- 7. The client is pointed at an incorrect DNS server (e.g., ISP DNS instead of the internal DC), so it cannot locate the domain controller.
- 8. The user's computer or user object sits in an OU with logon-hour or workstation restrictions applied by GPO.
- 9. The user's Kerberos ticket/security token was not refreshed after a group-membership change, so NTFS permissions on the HR folder do not yet reflect current membership.
- 10. The specific Domain Controller the client authenticates against is unreachable or its Netlogon service has stopped.

7.2 Step-by-Step Troubleshooting

1. Confirm the exact error message with the user (e.g., 'incorrect password' vs 'account locked' vs 'no logon servers available').
2. Have the user retype the new password carefully; verify Caps Lock and keyboard layout.
3. In ADUC, check the account's Account tab for Disabled, Locked, or Expired status.
4. Review Security Event Log on the DC for Event ID 4625 (failed logon) and 4740 (account lockout) to see the source of failed attempts.
5. Run `repadmin /replsummary` and `repadmin /showrepl` on both DCs to confirm the password change has replicated.
6. On the client, run `ipconfig /all` to confirm the DNS server is the internal DC, not an external/ISP address.
7. Test name resolution: `nslookup techsecure.local` and `ping DC01 / DC02` from the client.
8. Check time synchronization with `w32tm /query /status` on both the client and the DC (must be within 5 minutes).
9. Run `gpresult /r` (or `/h report.html`) on the client to confirm no restrictive logon-hours/workstation GPO is blocking access.

10. Compare the user's current group membership (ADUC > Member Of) against the HR-Shared NTFS/share ACL.
11. If locked out, unlock the account; if replication was delayed, force it with repadmin /syncall, then have the user log off/on to refresh their Kerberos ticket and group token.
12. Confirm the fix by having the user log in and open the HR-Shared folder, then document the resolution.

7.3 Active Directory Components to Check

- Both Domain Controllers (DC01, DC02) — status, replication health, and Netlogon service
- DNS — SRV records, internal DNS resolution on the client
- Kerberos / KDC — ticket issuance and time synchronization
- Group Policy Objects — logon-hour, workstation, and security GPOs applied to the user's OU
- Security Groups / OU membership — whether it matches the HR-Shared folder ACL
- NTFS and Share permissions on the HR-Shared folder

7.4 Relevant Windows Logs

- Security Event Log — Event IDs 4625 (failed logon), 4740 (account lockout), 4767 (account unlocked), 4768/4769 (Kerberos TGT/service ticket issuance)
- System Log — Netlogon and time-service (W32Time) errors
- DNS Server Log — resolution failures for the domain or SRV records
- Group Policy Operational Log — GPO processing errors on the client
- Directory Service Log — AD replication errors between DC01 and DC02

7.5 Verifying DNS, Group Policy, and Kerberos

DNS: run `ipconfig /all` on the client to confirm it points only to internal DNS servers, then `nslookup techsecure.local` and `nslookup -type=srv _ldap._tcp.dc._msdcs.techsecure.local` to confirm the domain and DC resolve correctly. Group Policy: run `gpresult /r` for a quick summary or `gpresult /h report.html` for a full report, and open `rsop.msc` to see exactly which GPOs are applied and whether any deny logon rights. Kerberos: run `klist` to view current tickets on the client, check Security Event Log IDs 4768 (TGT requested) and 4769 (service ticket requested) on the DC for success/failure, and confirm `w32tm /query /status` shows the client within 5 minutes of the DC's time, since Kerberos authentication fails silently outside that window.

7.6 Final Incident Report

Incident Summary: A user was unable to log on to the domain and could not access the HR-Shared folder the day after an administrator reset their password.

Root Cause: The password reset was performed on DC01 but had not yet replicated to DC02 by the time the user attempted to log on from a workstation authenticating against DC02, causing intermittent logon failures; in parallel, the user's HR-department group membership had been updated at the same time as the reset, but the user's existing Kerberos ticket still carried the old group token, so the HR-Shared folder's NTFS permissions did not recognize the user's updated group membership until the ticket was refreshed.

Solution / Resolution: Forced immediate replication between DC01 and DC02 with `repadmin /syncall`, confirmed via `repadmin /showrepl` that the new password hash was present on both DCs, then had the user fully log off and log back on to obtain a fresh Kerberos TGT reflecting current group membership. DNS on the affected workstation

was also corrected to point exclusively at the internal domain controllers to prevent future logon-server discovery issues. After these steps the user authenticated successfully and regained access to the HR-Shared folder.

Preventive Recommendation: Reduce AD replication interval expectations by validating repadmin /replsummary shows no failures before closing password-reset tickets, and add a standard step to the reset procedure instructing users to fully log off/on (not just lock/unlock) after any password or group-membership change.

8. Challenges

- Balancing least-privilege permission design against the practical need for IT staff to perform cross-department support and backups.
- Designing an OU structure that scales cleanly if TechSecure Solutions opens additional branch offices beyond the current two.
- Deciding where to draw the line between department-level GPOs and organization-wide baseline GPOs without creating policy conflicts.
- Building a Kali enumeration workflow that stays strictly defensive (read-only reconnaissance) and does not stray into exploitation.

9. Conclusion

This assignment walked through the full lifecycle of securing a mid-sized organization's Active Directory environment: designing a forest/domain/OU structure aligned to TechSecure Solutions' five departments and two branches, planning users, groups and least-privilege folder permissions, defining ten Group Policies mapped to specific attack scenarios, and laying out concrete hands-on steps for both the Windows Server AD practical and the Kali Linux defensive enumeration exercise. The closing case study reinforced how replication delays, stale Kerberos tickets and DNS misconfiguration can all masquerade as simple 'wrong password' issues, underscoring why a structured, component-by-component troubleshooting approach is essential for any Active Directory administrator or security analyst.

10. References

- Microsoft Learn — Active Directory Domain Services Overview
- Microsoft Learn — Group Policy Objects and Security Baselines
- Microsoft Learn — Kerberos Authentication Overview
- Nmap Reference Guide — nmap.org/book/man.html
- enum4linux-ng Documentation — github.com/cddmp/enum4linux-ng
- draw.io / diagrams.net Documentation — diagrams.net/doc